BELTTRACK MARTIAL ARTS MANAGEMENT OS

Gating Architecture Specification: 8 Types & Detailed Breakdown

Security Model: Hard vs. Soft Gating | Zero-Monetization Guarantee | Date: November 2026

GATING PHILOSOPHY: PRIVACY & INTEGRITY OVER COMMERCIAL PAYWALLS

Unlike commercial SaaS platforms, BeltTrack operates with ZERO feature tiers, paywalls, or subscriptions.

1. GATING TAXONOMY: HARD GATING VS. SOFT GATING

HARD GATING (Cryptographic & Server-Enforced)

Enforced at DB (RLS), Edge Middleware, and HTTP protocol.

SOFT GATING (UI & Workflow Guidance)

Enforced via UI banners, role preview toggles, and modals.

2. MASTER GATING CLASSIFICATION MATRIX

Gating Mechanism				
1. Multi-Tenant Isolation	HARD	PostgreSQL RLS / Prisma	NO (Impossible)	Zero rows returned
2. Rate Limiting & Abuse	HARD	Edge Middleware / In-Memory	NO (Impossible)	HTTP 429 Too Many Req
3. CSRF & Origin Guard	HARD	Edge Middleware Host Check	NO (Impossible)	HTTP 403 Forbidden
4. Cookie Security (HttpOnly)	HARD	Browser Engine / TLS	NO (Impossible)	document.cookie empty
5. Ledger Immutability	HARD	Prisma Schema / Route API	NO (Impossible)	No UPDATE/DELETE
6. Minor / Guardian Safety	HARD	Zod Schemas / DB FK	NO (Impossible)	HTTP 400 Bad Request
7. Member Approval (Pending)	HYBRID	Server API (H) / UI (S)	Partial (Preview UI)	Roster / Tech lock
8. Email Verification Code	SOFT	UI Banner / OTP Resend	YES (Audit mode)	Persistent Warning

3. DETAILED BREAKDOWN: HARD GATING MECHANISMS

Enforced at the Database, Protocol, and Server Runtime Layers - Completely Non-Bypassable

A. Multi-Tenant Isolation (school_id Foreign Key & RLS Boundary)

Threat Mitigated: Cross-tenant data exposure (e.g., Academy A viewing Academy B students or ledgers).

Enforcement: PostgreSQL Row-Level Security (RLS) policies and Prisma client extensions enforce that every query

`Source Reference: prisma/schema.prisma | src/lib/prisma-extension.ts`

LedgerEntry. Corrections strictly require issuing an offsetting reversal entry (CORRECTION_REVERSAL with REC-YYYY-DISC-XXXX).

B. Network Abuse & Sliding-Window Rate Limiting

Threat Mitigated: Brute-force credential stuffing, join code enumeration, and DoS request flooding.

Enforcement: Next.js Middleware evaluates in-memory sliding-window IP limits before request execution: /api/auth/login (5

`Source Reference: src/middleware.ts | src/lib/rate-limit.ts`

C. CSRF Origin & Host Validation Guard

Threat Mitigated: Unauthorized cross-site form submissions or forged API mutations from third-party sites.

Enforcement: Middleware inspects all state-changing HTTP requests (POST, PUT, PATCH, DELETE) targeting /api/*. If

`Source Reference: src/middleware.ts | src/lib/session-security.ts`

full name and email. Access is strictly scoped to linked GuardianStudent relations.

D. Session Cookie Security Flags (HttpOnly, Secure, SameSite=Lax)

Threat Mitigated: XSS session hijacking, public Wi-Fi eavesdropping, and cross-site subrequest leakage.

Enforcement: Enforced by the browser engine. HttpOnly prevents document.cookie reads;

`Source Reference: src/lib/supabase/server.ts | src/middleware.ts`

E. Ledger Immutability & Reversal Accounting (Zero-Monetization)

Threat Mitigated: Financial record manipulation, backdating tuition, and ledger tampering.

Enforcement: The database schema and API expose zero UPDATE or DELETE endpoints for

`Source Reference: prisma/schema.prisma | src/components/home/manual-ledger-modal.tsx`

F. Minor Student & Guardian Safety Gate

Threat Mitigated: Unsupervised minor registration or unauthorized adult access to child records.

Enforcement: The registration schema enforces isMinor logic: minor students cannot register without verified guardian

`Source Reference: src/lib/validation/schemas.ts | src/components/home/student-join-modal.tsx`

4. SOFT & HYBRID GATING (PROGRESSIVE ONBOARDING)

Workflows Designed for Educational Auditing, Persona Previews, and Frictionless Evaluation

A. Member Enrollment Approval (PENDING_APPROVAL) - HYBRID

Behavior: HYBRID GATING

When students register via join code, the API hard-gates roster and technique logs until approved by a

`Components: src/components/home/student-join-modal.tsx | src/components/home/member-approval-modal.tsx`

- Apply SOFT Gating: Whenever guiding user completion, demonstrating personas, or providing educational UI hints.

B. Email Verification (6-Digit OTP Confirmation) - SOFT GATED

Behavior: SOFT GATING

Head coaches with unverified emails are not locked out of their session. A persistent, prominent

`Components: src/components/home/email-verification-banner.tsx | src/lib/email-verification.ts`

C. Interactive Persona Switcher (Owner, Coach, Student, Guardian) - SOFT GATED

Behavior: SOFT GATING (PREVIEW AUDIT)

The homepage role switcher dynamically toggles between personas in client state, allowing academy owners to

`Components: src/context/auth-context.tsx | src/components/layout/top-nav.tsx`

5. WHAT IS EXPLICITLY NOT GATED (ZERO-MONETIZATION CORE)

PRD MANDATE & ARCHITECTURAL INVARIANT (AGENTS.md)

"Tier: No feature tiers exist; the platform has zero tiers, zero feature paywalls, and zero tiered subscriptions."

SUMMARY COMPARISON: WHEN TO APPLY HARD VS. SOFT GATING

- Apply HARD Gating: Whenever data privacy, cross-tenant isolation, or financial records are at stake.